

Esame Cybersecurity 5-6

Introduzione

Ciascuno studente risponderà ad almeno tre domande scelte tra quelle proposte di seguito.

Non sono richiesti temi elaborati: le risposte devono essere concise e precise.

Attenetevi allo scenario descritto e, soprattutto, evitate affermazioni generiche o approssimative.

Si valutano contenuti tecnici e specifici, non la capacità di riempire pagine.

Breve reminder relativo alle metodologie ISO 27001, GDPR e CSF.

ISO 27001 (Annex A)

- Controlli Organizzativi (37 controlli)
 - Cosa copre: Policy di sicurezza, ruoli e responsabilità, classificazione delle informazioni, gestione degli asset, supply chain, threat intelligence (nuovo controllo molto rilevante).
 - Focus: Come l'azienda struttura le proprie regole e gestisce i fornitori cloud/terze parti.
- Controlli sulle Persone (8 controlli)
 - Cosa copre: Screening dei dipendenti, on-boarding/off-boarding, formazione sulla consapevolezza (security awareness), accordi di riservatezza (NDA).
 - Focus: Il lato "human factor", cruciale per evitare il phishing e gestire l'Identity Management.
- Controlli Fisici (14 controlli)
 - Cosa copre: Perimetri di sicurezza fisica, controlli di accesso agli uffici e ai data center, protezione contro minacce ambientali, smaltimento sicuro delle apparecchiature (clear desk and clear screen).
 - Focus: La protezione dell'hardware che ospita i dati.
- Controlli Tecnologici (34 controlli)
 - Cosa copre: Crittografia, mascheramento dei dati (data masking), prevenzione della perdita di dati (DLP - Data Leakage Prevention), gestione delle vulnerabilità, log e monitoraggio, sicurezza delle reti e del cloud.
 - Focus: È il cuore tecnico per data breach e architetture di rete.

NIST Cybersecurity Framework (CSF) 2.0

Le Core Functions:

- 1) Govern (Governare)
 - a) Stabilisce e monitora la strategia di gestione del rischio di cybersecurity dell'organizzazione, le aspettative e le policy. È il "collante" che lega la sicurezza agli obiettivi di business.
- 2) Identify (Identificare)
 - a) Comprendere il contesto aziendale, le risorse che supportano le funzioni critiche e i relativi rischi.

- b) Esempi: Inventario hardware/software, valutazione dei rischi, identificazione delle vulnerabilità.
- 3) Protect (Proteggere)
 - a) Sviluppare e implementare le salvaguardie adeguate per garantire l'erogazione dei servizi.
 - b) Esempi: Identity & Access Management (IAM), formazione del personale, crittografia dei dati a riposo e in transito.
- 4) Detect (Rilevare)
 - a) Definire le attività per identificare il verificarsi di un evento di cybersecurity in modo tempestivo.
 - b) Esempi: Monitoraggio continuo della rete, sistemi SIEM/SOC, rilevamento di anomalie.
- 5) Respond (Rispondere)
 - a) Le azioni da intraprendere quando viene rilevato un incidente per contenerne l'impatto.
 - b) Esempi: Piano di risposta agli incidenti (Incident Response Plan), mitigazione, comunicazioni (es. notifica al Garante Privacy ex Art. 33 GDPR).
- 6) Recover (Ripristinare)
 - a) Le attività per ripristinare le capacità o i servizi compromessi durante l'attacco.
 - b) Esempi: Piani di Disaster Recovery (DR), ripristino dei backup, lezioni apprese (post-mortem).

GDPR

Articolo 35 del GDPR. Lo standard prevede che la DPIA (Data Protection Impact Assessment) debba contenere almeno quattro elementi obbligatori (comma 7), che rappresentano le fasi dell'assessment:

1. Descrizione sistematica dei trattamenti
 - Cosa richiede: Una mappatura chiara del ciclo di vita del dato (data flow). Chi raccoglie cosa, dove viene archiviato, a chi viene trasferito e per quanto tempo viene conservato. Devono essere esplicitate anche le finalità e i legittimi interessi.
1. Valutazione di necessità e proporzionalità:
 - Cosa richiede: La dimostrazione che il trattamento rispetti i principi fondamentali della privacy (minimizzazione dei dati, limitazione della finalità). Il dato raccolto è strettamente necessario per lo scopo prefissato?
1. Valutazione dei rischi per i diritti e le libertà:
 - Cosa richiede: L'identificazione delle minacce (es. accesso abusivo, modifica indesiderata, perdita dei dati) e la stima del rischio in termini di gravità e probabilità.
 - **Attenzione:** qui il rischio non è valutato in termini di danno economico per l'azienda (come nel ISO 27001), ma in termini di danno fisico, materiale o immateriale per le persone fisiche (discriminazione, furto d'identità, perdite finanziarie, danni alla reputazione).
1. Misure previste per affrontare i rischi (Mitigazione):
 - Cosa richiede: qui entrano in gioco ISO 27001 e CSF.

Domanda 1

Analisi e gestione del rischio post Data Breach

Modello Architetture di riferimento: Piattaforma E-commerce in Cloud.

L'architettura comprende un Frontend Web (esposto su Internet tramite Web Application Firewall), un Application Server interno e un Database relazionale che memorizza le anagrafiche dei clienti, gli storici degli ordini e i token di pagamento.

Domanda:

A seguito di un attacco ransomware che ha compromesso l'Application Server e portato all'esfiltrazione del Database clienti nell'architettura descritta, delinea le fasi di analisi e gestione del rischio. In conformità al GDPR, come valuteresti l'impatto sui diritti e le libertà degli interessati? Quali misure tecniche e organizzative (ispirate all'ISO 27001 o NIST CSF) proporresti nel piano di remediation per mitigare il rischio residuo ed evitare incidenti futuri?

Domanda 2

Privacy vs. Protezione dei Dati (Cybersecurity)

Modello Architetture di riferimento: Sistema CRM (Customer Relationship Management) erogato in SaaS (Software as a Service).

Un'azienda utilizza un CRM cloud per gestire i contatti commerciali. Il fornitore SaaS garantisce crittografia end-to-end, backup orari e autenticazione a due fattori per tutti gli accessi.

Domanda:

Utilizzando il modello CRM descritto come caso di studio, argomenta la differenza fondamentale tra "Data Privacy" (es. liceità, minimizzazione, diritti dell'interessato) e "Data Protection/Cybersecurity" (es. confidenzialità, integrità, disponibilità). Spiega, facendo esempi pratici applicati a questo scenario, come un'azienda possa avere un sistema tecnologicamente ineccepibile dal punto di vista della Cybersecurity (secondo i canoni ISO 27001 o CSF), ma essere contemporaneamente in grave violazione dei principi di Privacy dettati dal GDPR.

Domanda 3

Vulnerabilità e Minacce sui diversi Tipi di Dato

Modello Architetture di riferimento: Infrastruttura IoT (Internet Of Things) per una Smart City.

L'architettura è composta da sensori ambientali (temperatura, inquinamento) e telecamere di video-sorveglianza stradale distribuiti in città. Questi dispositivi inviano dati a un "Edge Gateway" locale, che a sua volta trasmette le informazioni a un Data Lake (è un enorme archivio centralizzato che permette di memorizzare enormi quantità di dati nel loro formato originale, grezzo, senza doverli prima strutturare o elaborare) centralizzato nel cloud per l'analisi.

Domanda:

Analizza l'architettura IoT proposta e classifica almeno tre diverse tipologie di dati trattati dal sistema (ad esempio: dati personali sensibili, dati operativi aggregati, dati pubblici). Per ciascuna categoria di dato identificata, descrivi una vulnerabilità specifica dell'architettura e una potenziale minaccia che potrebbe sfruttarla, valutando le differenze di impatto (es. impatto sulla privacy vs. impatto sulla disponibilità del servizio al cittadino).

Domanda 4

Modello di Identity Management

Modello Architetture di riferimento: Rete Aziendale con paradigma Zero Trust.

Un'infrastruttura ibrida in cui i dipendenti accedono sia a server legacy on-premise sia a servizi cloud (es. Microsoft 365, AWS). Non esiste una VPN tradizionale; l'accesso avviene tramite un Identity Provider (IdP) centralizzato che verifica l'identità, la salute del dispositivo e il ruolo dell'utente prima di concedere l'accesso alla singola risorsa.

Domanda:

Descrivi i concetti fondanti di un modello di Identity and Access Management (IAM), differenziando chiaramente le fasi di autenticazione e autorizzazione. Applicando il modello RBAC (Role-Based Access Control) all'architettura Zero Trust descritta, spiega come strutturaresti la gestione degli accessi e quali controlli (facendo riferimento a ISO 27001) implementeresti per garantire il principio del "privilegio minimo".

Domanda 5

Privacy and Security Assessment in ambito Sanitario

Modello Architettuale di riferimento: Sistema Informativo Ospedaliero (HIS).

Un'infrastruttura di rete ospedaliera che fa dialogare le Cartelle Cliniche Elettroniche (archivi strutturati dei pazienti e della loro storia clinica), i dispositivi medici salvavita connessi in rete (IoMT - Internet of Medical Things. Spesso architetture obsolete e insicure) e un portale web esterno tramite cui i pazienti possono scaricare i propri referti.

Domanda:

Dovendo condurre un assessment integrato sull'infrastruttura ospedaliera descritta, illustra i passaggi metodologici chiave. In particolare, spiega come strutturaresti una DPIA (Data Protection Impact Assessment) per i dati sanitari trattati nel portale web (GDPR) e come condurresti parallelamente un security assessment sui dispositivi IoMT utilizzando le funzioni core del NIST CSF (Identify, Protect, Detect, Respond, Recover).

- IoMT Ospedaliero: sono i dispositivi utilizzati fisicamente all'interno delle strutture sanitarie. Dal punto di vista della cybersecurity, sono i più critici perché un loro malfunzionamento (o un attacco hacker) può avere un impatto diretto e immediato sulla vita del paziente.
 - Pompe di infusione intelligenti (Smart Pumps): Dispositivi che erogano farmaci, fluidi o nutrienti direttamente nel sangue del paziente. Sono connesse alla rete per scaricare automaticamente le librerie dei farmaci e aggiornare la cartella clinica.
 - Monitor multiparametrici da posto letto: I classici schermi accanto al letto del paziente che tracciano ECG, pressione, ossigenazione e respirazione, inviando allarmi e dati in tempo reale alla postazione centrale degli infermieri.
 - Letti ospedalieri intelligenti (Smart Beds): Letti dotati di sensori che monitorano il peso del paziente, i parametri vitali di base e rilevano se il paziente sta cercando di alzarsi (prevenendo le cadute).
 - Macchinari di imaging connessi: Apparecchiature per risonanze magnetiche (MRI), TAC o radiografie che inviano enormi moli di dati (immagini DICOM) direttamente ai server centrali dell'ospedale (sistemi PACS).
 - Frigoriferi intelligenti per farmaci e vaccini: Sensori IoT che monitorano costantemente la temperatura e avvisano se la catena del freddo si interrompe.
- IoMT Domestico e Personale (In-Home / Wearables): sono i dispositivi che il paziente utilizza a casa o porta addosso per il telemonitoraggio. Spesso comunicano tramite Bluetooth con lo smartphone del paziente e poi via cloud al medico.
 - Dispositivi impiantabili connessi: Pacemaker e defibrillatori cardioversori impiantabili (ICD) che trasmettono in remoto i dati sul ritmo cardiaco al cardiologo, senza che il paziente debba recarsi in clinica.
 - Sistemi di monitoraggio continuo del glucosio (CGM): Sensori sottocutanei per pazienti diabetici che misurano la glicemia 24 ore su 24 e inviano i dati a un'app o direttamente alla cartella clinica.
 - Holter digitali e Smartwatch medici: Dispositivi indossabili (certificati come dispositivi medici) per il monitoraggio continuo dell'ECG, della saturazione dell'ossigeno o della pressione sanguigna.
 - Inhalatori intelligenti (Smart Inhalers): Per pazienti asmatici, registrano quando e come viene preso il farmaco e avvisano il medico se ci sono anomalie nell'aderenza alla terapia.
- 3. IoMT Comunitario e Logistico: dispositivi sparsi sul territorio o usati per tracciare le risorse.
 - Chioschi per la telemedicina (Telehealth Kiosks): Cabine dislocate in farmacie o centri commerciali dotate di strumenti diagnostici base (pressione, temperatura, video-consulti) connesse agli ospedali.
 - Sistemi di tracciamento RTLS (Real-Time Location Systems): Tag RFID o sensori applicati su sedie a rotelle, carrelli salvavita o pompe di infusione per rintracciarli immediatamente all'interno di un grande ospedale.

Domanda 6

Anatomia di un Attacco in Rete e Malware

Attacchi in Rete, Malware e Difesa in Profondità

Modello Architettuale di riferimento: Rete aziendale con applicazione web pubblica esposta su Internet.

Un'azienda dispone di una rete interna (LAN) connessa a Internet tramite un router/firewall perimetrale e di un'applicazione web a tre livelli (front-end, application server, database relazionale) esposta pubblicamente tramite WAF. I dipendenti utilizzano client di posta elettronica e accedono a risorse condivise. Il reparto IT ha rilevato una serie di anomalie: traffico di rete verso indirizzi IP esterni sconosciuti, workstation che inviano email in autonomia, tentativi di SQL injection sul modulo di login dell'applicazione web, richieste anomale che suggeriscono scraping automatizzato e un picco di traffico verso endpoint non documentati dell'API REST interna.

Domanda:

Analizzando le anomalie descritte, formula un'ipotesi motivata sulle minacce in corso.

In particolare:

1. identifica e distingui almeno tre categorie di malware potenzialmente coinvolte (tra virus, worm, trojan, ransomware, spyware, keylogger, adware, rootkit, bot malevoli, zombie), spiegando come ciascuna potrebbe aver sfruttato vettori specifici presenti nello scenario (phishing, email spam, backdoor, tecnologie trasmissive della rete);
2. confronta le differenze operative tra un attacco DDoS condotto tramite botnet di macchine zombie e un attacco man-in-the-middle realizzato tramite sniffing del traffico non cifrato, indicando per ciascuno le contromisure prioritarie;
3. illustra il ruolo del WAF come difesa applicativa — differenziandolo da un firewall di rete tradizionale — e analizza come i meccanismi del WAF contrastano almeno due delle minacce rilevate sull'applicazione web (es. SQL injection, XSS, accesso illecito alle risorse, attacchi ai workflow). Concludi argomentando come la corretta configurazione dei dispositivi di rete (segmentazione, hardening, regole di accesso) costituisca uno strato difensivo complementare e indispensabile nella logica di una difesa in profondità (defense-in-depth).